

Module 1 – Cloud Platform & Terraform Security Review

Comprehensive Security Assessment

Infrastructure-as-Code Security Assessment across AWS, Azure, and GCP

Assessment Scope

This assessment evaluates the security posture of the reference Infrastructure-as-Code (IaC) repository across AWS, Azure, and GCP. The review identifies security weaknesses within Terraform configurations before deployment and prioritizes remediation based on business impact and likelihood of exploitation.

Key Findings

- Critical Issues: 9 findings requiring immediate remediation
- High-Risk Issues: 11 findings requiring urgent attention
- Total Findings: 25 security observations documented

Critical Risks Without Remediation

- Data breaches and intellectual property exposure
- Credential theft and privilege escalation attacks
- Compliance violations and regulatory penalties
- Ransomware impact and business continuity threats

Risk Assessment Methodology

Severity	Description
Critical	Immediate exploitation leading to data compromise or privilege escalation
High	Significant security weakness requiring urgent remediation
Medium	Security weakness with limited exploitation scenarios
Low	Best practice improvement

Detailed Security Findings

Storage Security

Finding F-001, F-002, F-003: Public Storage Buckets

Severity: **CRITICAL**

- Issue: Multiple cloud storage services allow unrestricted public access

- AWS: S3 bucket without Block Public Access enabled
- Azure: Blob container configured for anonymous access
- GCP: Cloud Storage bucket with all Users IAM binding

Business Impact: Data leakage, IP exposure, regulatory non-compliance

Recommendations:

- Disable all public access policies
- Enable encryption at rest (SSE-KMS)
- Enable versioning and object lock
- Apply least privilege IAM policies

Database Security

Finding F-004 to F-005: Public Database Access

Severity: **CRITICAL**

- Issue: Publicly accessible databases without encryption
- RDS instances accessible from the internet
- No encryption at rest configured
- Deletion protection disabled

Business Impact: Database compromise, data theft, ransomware attacks

Recommendations:

- Deploy databases in private subnets behind security groups
- Enable KMS encryption at rest
- Enforce TLS for data in transit
- Configure automated backups with 30+ day retention

Identity & Access Management

Finding F-006 to F-008: Excessive Permissions

Severity: **CRITICAL**

- Issue: Wildcard IAM permissions and overly broad role assignments
- AWS: IAM policy with Action:"*" and Resource:"*"
- Azure: Contributor role at Subscription level

- GCP: Service Account with Owner role

Business Impact: Privilege escalation, lateral movement, complete cloud takeover

Recommendations:

- Implement least privilege principle for all roles
- Separate duties and role responsibilities
- Use temporary privileged access with time limits
- Enforce MFA and OIDC federation

Secrets Management

Finding F-009: Hardcoded Credentials

Severity: **CRITICAL**

- Issue: Credentials and API keys committed to Terraform and version control

Recommended Architecture:

- Use OIDC federation with cloud providers
- Store secrets in AWS Secrets Manager, Azure Key Vault, or Google Secret Manager
- Reference secrets from Terraform using data sources
- Implement secret rotation policies

Network Security

Finding F-010 to F-012: Unrestricted Network Access

Severity: **CRITICAL / HIGH**

- Issue: Security groups and firewall rules allow unrestricted ingress
- AWS: Security Group permits 0.0.0.0/0 on SSH (port 22)
- Azure: NSG allows unrestricted RDP (port 3389)
- GCP: Firewall allows unrestricted ingress globally

Recommendations:

- Deploy Bastion hosts for remote administrative access
- Implement VPN for secure connectivity
- Apply Zero Trust principles and network segmentation

- Use private endpoints for cloud services

Logging & Monitoring

Finding F-015 to F-017: Insufficient Audit Logging

Severity: **HIGH**

- Issue: Audit logging disabled or incomplete across cloud platforms

Recommendations:

- Enable organization-wide CloudTrail in AWS
- Forward Azure Activity Logs to Log Analytics
- Enable Cloud Audit Logs for Admin and Data Access in GCP
- Centralize logs in SIEM for correlation and analysis

Complete Findings Register

ID	Category	Cloud	Finding	Severity
F-001	Storage	AWS	S3 bucket allows public read access	Critical
F-002	Storage	Azure	Blob Storage container configured for anonymous access	Critical
F-003	Storage	GCP	Cloud Storage bucket publicly accessible	Critical
F-004	Database	AWS	RDS publicly accessible	Critical
F-005	Database	AWS	RDS encryption disabled	Critical
F-006	IAM	AWS	IAM policy contains Action:"*" Resource:"*"	Critical
F-007	IAM	Azure	Contributor role assigned at subscription level	High
F-008	IAM	GCP	Service Account granted Owner role	High

F-009	Secrets	Multi	Credentials stored in Terraform variables	Critical
F-010	Network	AWS	Security Group permits 0.0.0.0/0 on SSH (22)	Critical
F-011	Network	Azure	NSG allows unrestricted RDP (3389)	Critical
F-012	Network	GCP	Firewall allows unrestricted ingress	High
F-013	Encryption	AWS	S3 default encryption disabled	High
F-014	Encryption	Azure	Storage Account encryption not enforced	High
F-015	Logging	AWS	CloudTrail disabled	High
F-016	Logging	Azure	Activity Logs not forwarded to Log Analytics	High
F-017	Logging	GCP	Cloud Audit Logs disabled for Data Access	High
F-018	Backup	AWS	RDS automated backup retention set to 0 days	High
F-019	Backup	AWS	Snapshot deletion protection disabled	Medium
F-020	Monitoring	Multi	No CSPM solution deployed	High
F-021	Compliance	Multi	Resources missing mandatory tags	Low
F-022	Governance	Multi	No policy-as-code validation	Medium
F-023	Supply Chain	Multi	Terraform modules not version pinned	Medium
F-024	Compute	AWS	EC2 IMDSv1 enabled	Medium

F-025	Logging	Multi	Logs not centralised	High
-------	---------	-------	----------------------	------

Remediation Roadmap

Timeline	Activities
Week 1	- Remove public storage access (F-001, F-002, F-003) - Disable public database access (F-004, F-005) - Restrict IAM wildcard permissions (F-006, F-007, F-008)
Week 2	- Enable encryption at rest and in transit (F-013, F-014) - Migrate secrets to cloud-native managers (F-009) - Restrict network access with security groups (F-010, F-011, F-012)
Week 3	- Enable CloudTrail, Activity Logs, and Audit Logs (F-015, F-016, F-017) - Centralize logs into SIEM (F-025) - Deploy Cloud Security Posture Management tools (F-020)
Week 4	- Configure automated backups and retention (F-018) - Enable snapshot protection (F-019) - Implement Policy-as-Code (F-022, F-023) - Enforce resource tagging (F-021)

Top 5 Priority Actions

- Remove all public storage access (F-001, F-002, F-003)
- Restrict wildcard IAM policies (F-006, F-007, F-008)
- Remove public database access (F-004, F-005)
- Migrate hardcoded secrets to secret managers (F-009)
- Enable comprehensive audit logging (F-015, F-016, F-017)

Conclusion

This assessment identified 25 critical security findings across storage, databases, identity management, networking, encryption, and logging. Immediate remediation of critical issues is essential to prevent data breaches, unauthorized access, and compliance violations.

By following the provided recommendations and remediation roadmap, the organization can significantly improve its cloud security posture and reduce risk exposure.